

Экзаменационные билеты по дисциплине Управление рисками информационной безопасности

Шмаков И.С.

2025-2026

**Федеральное государственное автономное образовательное учреждение
высшего образования «Московский государственный технический университет
имени Н.Э. Баумана (национальный исследовательский университет)»
(«МГТУ им. Н.Э. Баумана»)**

ЭКЗАМЕНАЦИОННЫЙ БИЛЕТ № 1
По дисциплине «Управление рисками информационной безопасности»

№	Вопрос / задача	Максимальная оценка в баллах
1	Что такое GitSCM - нарисуйте схему работы и описание самой работы. Какие основные команды Git (init, clone, add, commit, push) используются в типичном рабочем процессе разработки?	10
2	Опишите рекомендуемую структуру репозитория для проекта (README, src, tests, .gitignore, LICENSE) и объясните назначение каждого элемента.	10
3	Какие требования к оформлению README.md считаются минимальными для того, чтобы новый участник мог быстро начать работу с проектом?	10

Билет рассмотрен и утвержден на заседании кафедры от 25.05.2026г. протокол № 04.22-04/10ДСП

Заведующий кафедрой ИУ10 «ЗАЩИТА ИНФОРМАЦИИ»

А.М. Сычев

Федеральное государственное автономное образовательное учреждение
высшего образования «Московский государственный технический университет
имени Н.Э. Баумана (национальный исследовательский университет)»
(«МГТУ им. Н.Э. Баумана»)

ЭКЗАМЕНАЦИОННЫЙ БИЛЕТ № 2
По дисциплине «Управление рисками информационной безопасности»

№	Вопрос / задача	Максимальная оценка в баллах
1	Опишите базовые принципы работы в *nix-системах: файловая иерархия, права доступа (rwx), пользователи и группы. Опишите как работает chmod и chown, чем они отличаются?	10
2	Какие команды и утилиты используются для управления процессами в *nix (ps, top/htop, kill, nice) и в каких сценариях они применяются?	10
3	Как организовать безопасную работу в *nix-окружении для разработчика: изоляция окружения, работа с SSH-ключами, минимизация прав?	10

Билет рассмотрен и утвержден на заседании кафедры от 25.05.2026г. протокол № 04.22-04/10ДСП

Заведующий кафедрой ИУ10 «ЗАЩИТА ИНФОРМАЦИИ»

А.М. Сычев

Федеральное государственное автономное образовательное учреждение
высшего образования «Московский государственный технический университет
имени Н.Э. Баумана (национальный исследовательский университет)»
(«МГТУ им. Н.Э. Баумана»)

ЭКЗАМЕНАЦИОННЫЙ БИЛЕТ № 3
По дисциплине «Управление рисками информационной безопасности»

№	Вопрос / задача	Максимальная оценка в баллах
1	Что такое nmap и какие основные типы сканирования портов вы знаете (SYN scan, connect scan, UDP scan)?	10
2	Какие типы уязвимостей и неправильных конфигураций можно выявить с помощью nmap и его скриптов (NSE)?	10
3	Опишите типовой пайплайн: сканирование nmap → анализ открытых портов/сервисов → поиск уязвимостей → формирование отчёта.	10

Билет рассмотрен и утвержден на заседании кафедры от 25.05.2026г. протокол № 04.22-04/10ДСП

Заведующий кафедрой ИУ10 «ЗАЩИТА ИНФОРМАЦИИ»

А.М. Сычев

Федеральное государственное автономное образовательное учреждение
высшего образования «Московский государственный технический университет
имени Н.Э. Баумана (национальный исследовательский университет)»
(«МГТУ им. Н.Э. Баумана»)

ЭКЗАМЕНАЦИОННЫЙ БИЛЕТ № 4
По дисциплине «Управление рисками информационной безопасности»

№	Вопрос / задача	Максимальная оценка в баллах
1	Что такое риск в информационной безопасности и как он формально определяется через актив, угрозу, уязвимость и воздействие?	10
2	Опишите основные этапы процесса анализа рисков ИБ: идентификация активов, угроз, уязвимостей, оценка вероятности и ущерба, выбор мер обработки риска.	10
3	Чем отличаются подходы к управлению рисками: избежание, снижение, передача и принятие риска, и приведите пример для каждого подхода.	10

Билет рассмотрен и утвержден на заседании кафедры от 25.05.2026г. протокол № 04.22-04/10ДСП

Заведующий кафедрой ИУ10 «ЗАЩИТА ИНФОРМАЦИИ»

А.М. Сычев

Федеральное государственное автономное образовательное учреждение
высшего образования «Московский государственный технический университет
имени Н.Э. Баумана (национальный исследовательский университет)»
(«МГТУ им. Н.Э. Баумана»)

ЭКЗАМЕНАЦИОННЫЙ БИЛЕТ № 5
По дисциплине «Управление рисками информационной безопасности»

№	Вопрос / задача	Максимальная оценка в баллах
1	Какие основные виды рисков ИБ вы выделяете (технологические, организационные, человеческий фактор, внешние угрозы) и чем они отличаются по природе и управляемости?	10
2	Как практически связать результаты технических анализов (SAST, SCA, DAST, Docker CIS Benchmark) с оценкой рисков ИБ: какие метрики и находки должны попасть в модель риска?	10
3	Опишите, как выстроить цикл работы с рисками ИБ в организации: выявление и приоритизация, планирование мер, внедрение, мониторинг, пересмотр оценки риска и отчётность для стейкхолдеров.	10

Билет рассмотрен и утвержден на заседании кафедры от 25.05.2026г. протокол № 04.22-04/10ДСП

Заведующий кафедрой ИУ10 «ЗАЩИТА ИНФОРМАЦИИ»

А.М. Сычев

Федеральное государственное автономное образовательное учреждение
высшего образования «Московский государственный технический университет
имени Н.Э. Баумана (национальный исследовательский университет)»
(«МГТУ им. Н.Э. Баумана»)

ЭКЗАМЕНАЦИОННЫЙ БИЛЕТ № 6
По дисциплине «Управление рисками информационной безопасности»

№	Вопрос / задача	Максимальная оценка в баллах
1	Что такое Docker-образ и Docker-контейнер, и как выглядит типичный Dockerfile для приложения?	10
2	Объясните разницу между docker run, docker build, docker compose и приведите пример сценария использования каждого из них.	10
3	Какие практики позволяют уменьшить поверхность атаки в Docker-образах (минимальные базовые образы, non-root пользователь, multistage build)?. Опишите контекст безопасности и базовые правила безопасности.	10

Билет рассмотрен и утвержден на заседании кафедры от 25.05.2026г. протокол № 04.22-04/10ДСП

Заведующий кафедрой ИУ10 «ЗАЩИТА ИНФОРМАЦИИ»

А.М. Сычев

Федеральное государственное автономное образовательное учреждение
высшего образования «Московский государственный технический университет
имени Н.Э. Баумана (национальный исследовательский университет)»
(«МГТУ им. Н.Э. Баумана»)

ЭКЗАМЕНАЦИОННЫЙ БИЛЕТ № 7
По дисциплине «Управление рисками информационной безопасности»

№	Вопрос / задача	Максимальная оценка в баллах
1	Что такое Docker CIS Benchmark и зачем его применять к Docker-хосту и контейнерам?	10
2	Приведите примеры типичных рекомендаций Docker CIS Benchmark (конфигурация демона, ограничение ресурсов, управление секретами).	10
3	Как результаты проверки по Docker CIS Benchmark могут быть интегрированы в процесс CI/CD и отчётность по уязвимостям?	10

Билет рассмотрен и утвержден на заседании кафедры от 25.05.2026г. протокол № 04.22-04/10ДСП

Заведующий кафедрой ИУ10 «ЗАЩИТА ИНФОРМАЦИИ»

А.М. Сычев

Федеральное государственное автономное образовательное учреждение
высшего образования «Московский государственный технический университет
имени Н.Э. Баумана (национальный исследовательский университет)»
(«МГТУ им. Н.Э. Баумана»)

ЭКЗАМЕНАЦИОННЫЙ БИЛЕТ № 8
По дисциплине «Управление рисками информационной безопасности»

№	Вопрос / задача	Максимальная оценка в баллах
1	Объясните различия между SAST, SCA и IaC-анализом (на примере Semgrep, Dependency-Check, Checkov).	10
2	Как настроить и использовать Semgrep для анализа исходного кода: правило, таргеты, базовый вывод отчёта?	10
3	Как результаты SAST/SCA/IaC-сканов интегрируются в конвейер CI/CD и политику «quality gate» проекта?	10

Билет рассмотрен и утвержден на заседании кафедры от 25.05.2026г. протокол № 04.22-04/10ДСП

Заведующий кафедрой ИУ10 «ЗАЩИТА ИНФОРМАЦИИ»

А.М. Сычев

Федеральное государственное автономное образовательное учреждение
высшего образования «Московский государственный технический университет
имени Н.Э. Баумана (национальный исследовательский университет)»
(«МГТУ им. Н.Э. Баумана»)

ЭКЗАМЕНАЦИОННЫЙ БИЛЕТ № 9
По дисциплине «Управление рисками информационной безопасности»

№	Вопрос / задача	Максимальная оценка в баллах
1	Что такое DAST и чем отличается от SAST и SCA?	10
2	Опишите типовой рабочий процесс тестирования уязвимого веб-приложения с помощью OWASP ZAP (discovery, spider, active scan, отчёт).	10
3	Какие ограничения у DAST-подхода и как их компенсировать комбинацией с другими видами анализа?	10

Билет рассмотрен и утвержден на заседании кафедры от 25.05.2026г. протокол № 04.22-04/10ДСП

Заведующий кафедрой ИУ10 «ЗАЩИТА ИНФОРМАЦИИ»

А.М. Сычев

**Федеральное государственное автономное образовательное учреждение
высшего образования «Московский государственный технический университет
имени Н.Э. Баумана (национальный исследовательский университет)»
(«МГТУ им. Н.Э. Баумана»)**

ЭКЗАМЕНАЦИОННЫЙ БИЛЕТ № 10
По дисциплине «Управление рисками информационной безопасности»

№	Вопрос / задача	Максимальная оценка в баллах
1	Перечислите ключевые элементы оценки рисков ИБ, которые нужно учесть при итоговой работе по курсу.	10
2	Как результаты лабораторных работ (сканирование, SAST/SCA/DAST, Docker-аудит) могут быть использованы для обоснования остаточного риска?	10
3	Как оформить итоговый отчёт: структура разделов, минимальный набор приложений и артефактов, которые ожидает заказчик/руководитель?	10

Билет рассмотрен и утвержден на заседании кафедры от 25.05.2026г. протокол № 04.22-04/10ДСП

Заведующий кафедрой ИУ10 «ЗАЩИТА ИНФОРМАЦИИ»

А.М. Сычев
